Architecture Réseaux Entreprises (ARES)

Concevoir et valider les accès sécurisés

Brice - Ekane (brice.ekane@univ-rennes.fr)
ISTIC Rennes - France
2025-2026

`git clone https://github.com/bekane/ares.git`

Plan du module

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

Objectifs et parcours du module

À la fin du module, savoir :

1. traduire les besoins ARES en autorisations et refus explicites ;
2. placer tunnels, bastion, filtrage et DNS sur un schéma d'accès ;
3. réaliser le transit entre LAN avec WireGuard et routage conditionnel ;
4. prouver accès, isolation, diagnostic et révocation ;
5. expliquer l'apport du ZTNA pour un partenaire.

Aperçu de la section 1

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

Le cas ARES : quatre accès à concevoir

- **Intersite** : remplacer le GRE nu entre les deux routeurs par un chemin chiffré pour les flux métier autorisés.
- **Administration distante** : rejoindre un bastion puis `vm-mgnt`, sans ouvrir le management aux utilisateurs.
- **Télétravail** : rejoindre les ressources métier autorisées, avec un chemin DNS et une sortie Internet maîtrisés.
- **Partenaire** : atteindre une seule application en DMZ, sans accès latéral au LAN ni au management.

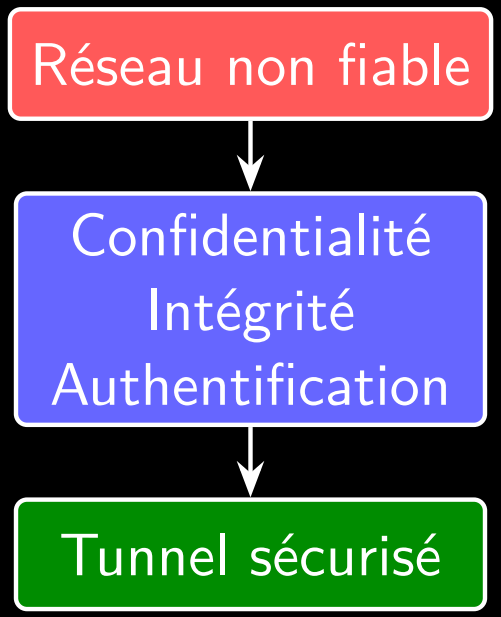
Continuité avec les modules précédents

M1 : zones et besoins. M2 : routes, NAT et filtrage. M3 : résolution DNS et dépendances des services.

Une matrice avant de choisir une technologie

Source	Destination / service	Identité à vérifier	Refus attendu
Site distant	Service métier prévu	Pair passerelle ; compte applicatif	Autres services
Administrateur	Bastion puis management	Pair + utilisateur habilité	Accès direct au management
Télétravailleur	Ressources métier	Pair + compte utilisateur	Management
Partenaire	Application DMZ / HTTPS	Utilisateur partenaire	LAN et management

Problématique d'ingénierie



Un VPN garantit-il que la machine distante est saine ?

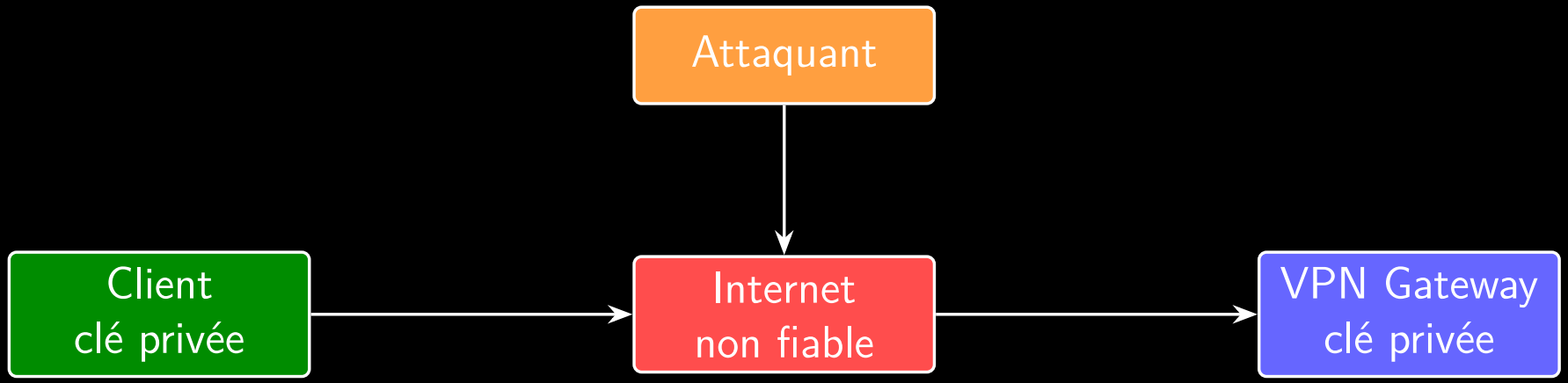
Non!

Sécuriser le transport $\neq$ sécuriser l'endpoint, l'identité utilisateur ou la posture du poste.

Identité, posture et moindre privilège

- Identité : utilisateur, machine, service account, MFA, groupe, rôle.
- Posture endpoint : chiffrement disque, EDR actif, OS à jour, certificat machine.
- Contexte : lieu, horaire, risque, sensibilité de l'application.
- Policy : donner accès à l'application nécessaire, pas à tout un réseau par défaut.
- Observabilité : journaliser qui accède à quoi et pourquoi l'accès est autorisé ou refusé.

Modèle de menace VPN



- Écoute passive, MITM, spoofing, replay, DoS.
- Vol de clé privée, endpoint compromis, fuite DNS.
- Erreur de routage, détournement de route, accès trop largement autorisé.

Que protège un tunnel chiffré et authentifié ? Que reste-t-il à protéger ?

Aperçu de la section 2

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

VPN : rappel utile

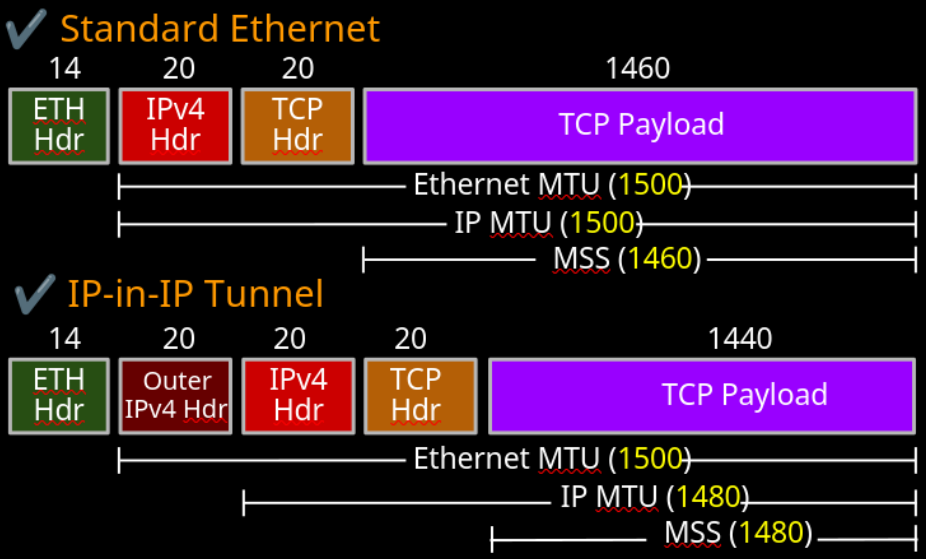
Définition

Un VPN transporte du trafic privé sur un réseau non fiable au moyen d'un tunnel chiffré.

- Remote access
- Site-à-site
- Accès d'administration

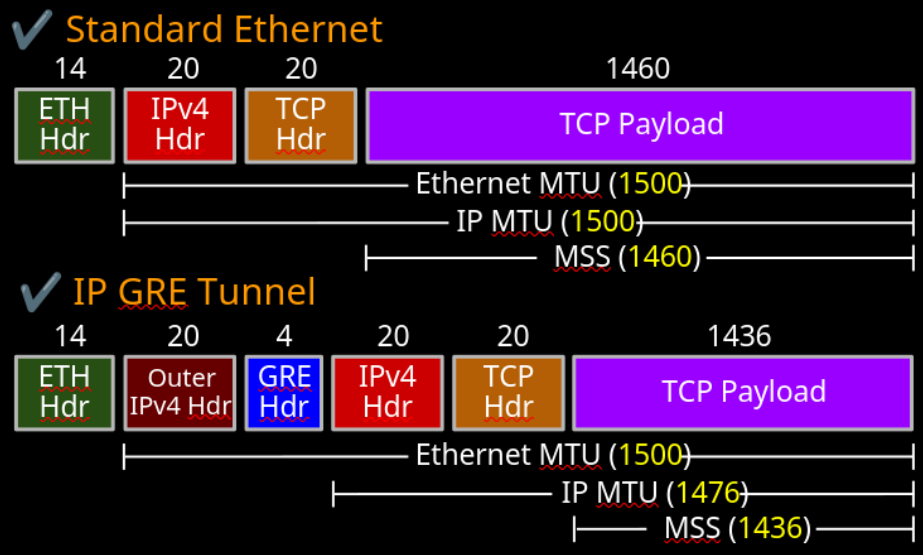
- Confidentialité
- Intégrité
- Authentification des pairs

IP-in-IP et GRE : tunnels non chiffrés



IP-in-IP

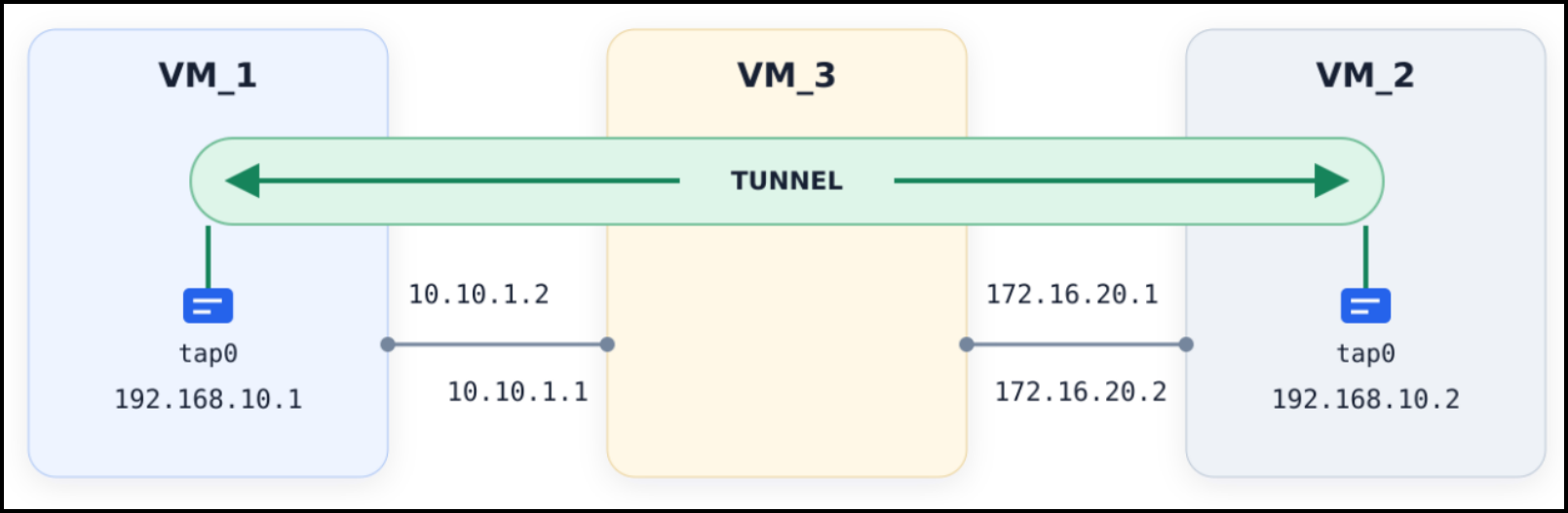
Transporte un paquet IP dans un autre paquet IP.



GRE

Encapsule plusieurs types de protocoles dans IP.

Underlay, overlay et décision de routage



- Underlay: réseau qui rend les deux extrémités du tunnel joignables ;
- Overlay: réseau logique transporté à l'intérieur du tunnel ;
- Routage: une décision pour atteindre l'endpoint, une autre pour le paquet interne.

Préparer GRE et un serveur HTTP de test

Prérequis : LAN et passerelles configurés, underlay joignable.
Exécuter sur chaque machine de la maquette (passerelles : root).

Passerelle A : `192.0.2.1`

```
ip tunnel add gre1 mode gre \
  local 192.0.2.1 remote 192.0.2.2
ip link set gre1 mtu 1476 up
ip route replace 10.100.2.0/24 dev gre1
sysctl -w net.ipv4.ip_forward=1
```

Passerelle B : `192.0.2.2`

```
ip tunnel add gre1 mode gre \
  local 192.0.2.2 remote 192.0.2.1
ip link set gre1 mtu 1476 up
ip route replace 10.100.1.0/24 dev gre1
sysctl -w net.ipv4.ip_forward=1
```

Hôte B : `10.100.2.10` **— réponse HTTP avec socat**

```
printf 'HTTP/1.0 200 OK\r\nContent-Length: 3\r\n\r\nOK\n' \
  > /tmp/gre-http.txt
socat -v TCP4-LISTEN:8000,reuseaddr,fork \
  SYSTEM:'cat /tmp/gre-http.txt; cat >/dev/null'
```

Autoriser GRE (protocole IP 47) entre passerelles et le transit TCP/8000 LAN ↔ GRE. Sur A : `curl http://10.100.2.10:8000/` doit retourner `OK`.

GRE : un tunnel ne chiffre pas le trafic

Maquette préparée : A → passerelle A → passerelle B → B.
Underlay : `192.0.2.1` ↔ `192.0.2.2`.

1. Préparer GRE entre les sites et un service HTTP sur B.
2. Capturer sur `wan0` de la passerelle A, puis lancer :

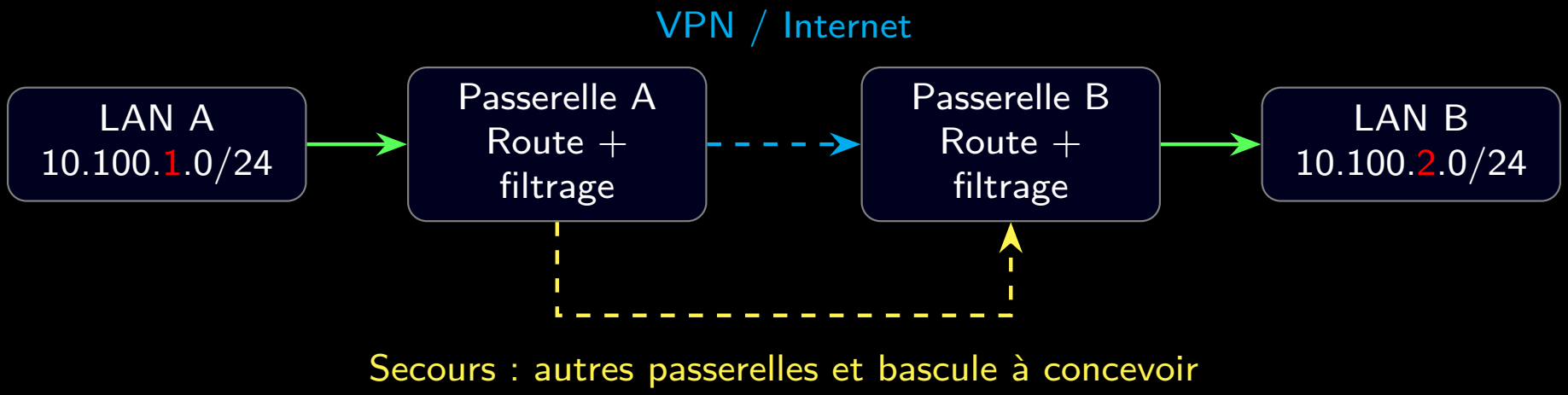
```
# Passerelle A : démarrer la capture avant la requête
tcpdump -ni wan0 -A 'ip proto 47'
# Hôte A : envoyer un contenu reconnaissable
curl 'http://10.100.2.10:8000/?message=bonjour-ARES'
```

3. GRE : `bonjour-ARES` est lisible dans la capture.
4. Rejouer via WireGuard : sur `wan0`, le contenu est chiffré.

À retenir : GRE seul encapsule sans chiffrer.
Utiliser HTTP : avec HTTPS, TLS chiffrerait déjà le contenu.

Site-à-site : relier les préfixes utiles

Le tunnel relie les passerelles ; routes et filtrage définissent les échanges.



1. Joindre

Préfixes distants.
Routes aller et retour.
Pas de chevauchement.

2. Filtrer

Services nécessaires.
Exemple : HTTPS.
Autres flux refusés.

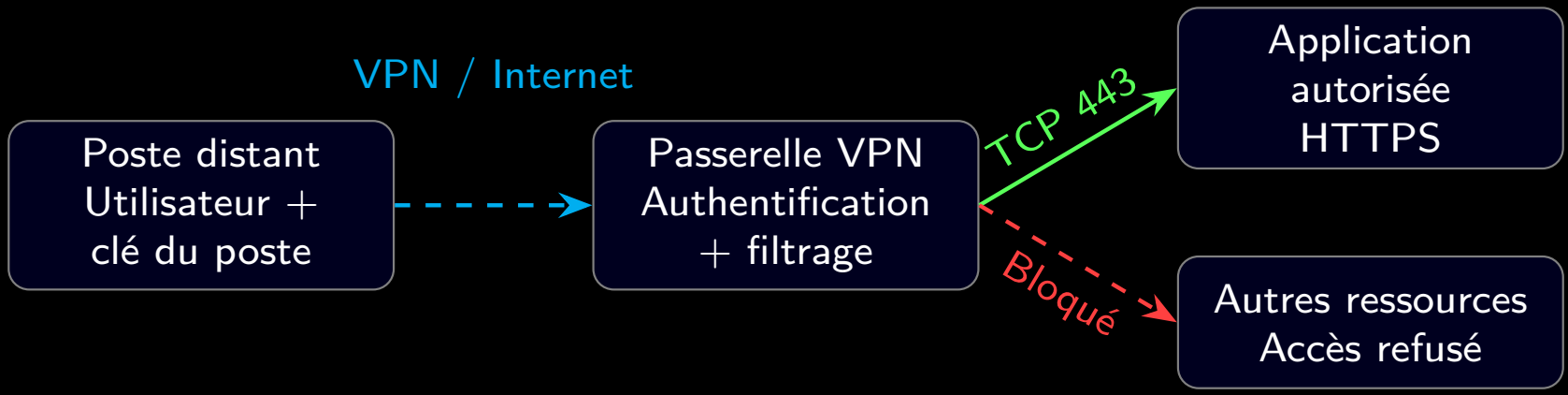
3. Éprouver la panne

Couper une passerelle.
Vérifier la bascule.
Sessions parfois rompues.

Le secours est une extension d'architecture ; la maquette A/B ne le réalise pas.

Accès distant : ouvrir un périmètre limité

Le poste rejoint les ressources autorisées selon son identité et ses droits.



1. Contrôler

Identifier poste et personne.
Vérifier la posture.
MFA via solution adaptée.

2. Limiter

Destinations et ports.
Routes nécessaires.
Tunnel partiel ou complet.

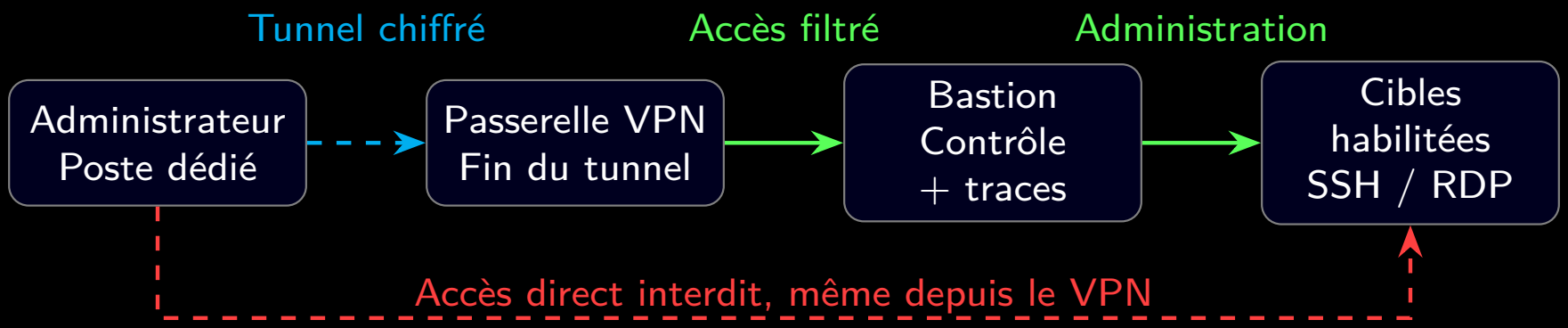
3. Révoquer

Retirer les droits.
Traiter les sessions.
Retester le refus d'accès.

Un tunnel établi ne prouve ni les droits ni la conformité du poste.

Bastion : imposer le chemin d'administration

Les cibles acceptent l'administration depuis le bastion ; le chemin direct est bloqué.



1. Concentrer

Imposer le bastion.
Limiter comptes et cibles.
Protéger les secrets.

2. Tracer

Identité, cible, heure.
Protéger les journaux.
Enregistrer si requis.

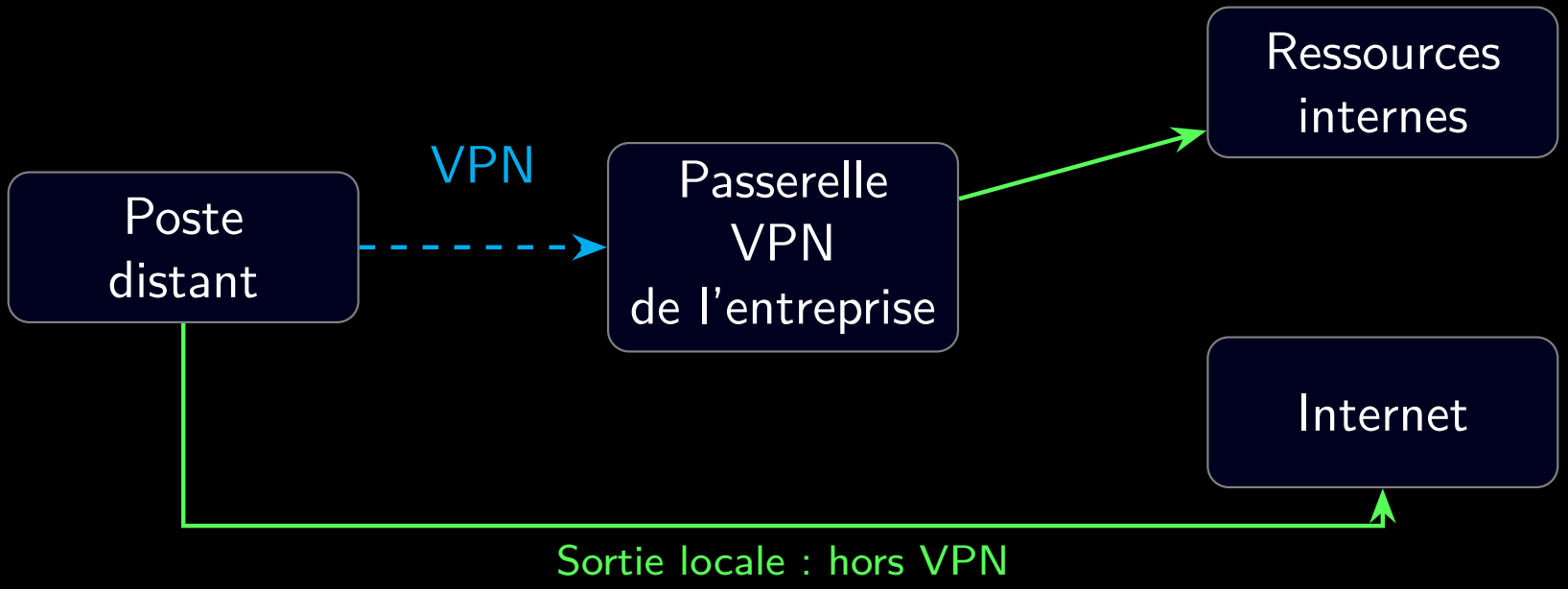
3. Vérifier

Via bastion : admis.
En direct : refusé.
Chercher les contournements.

Exemple avec VPN : le tunnel se termine sur la passerelle ; le bastion contrôle les sessions d'administration.

Télétravail : split tunnel

Les destinations internes choisies passent par le VPN ; Internet sort localement.



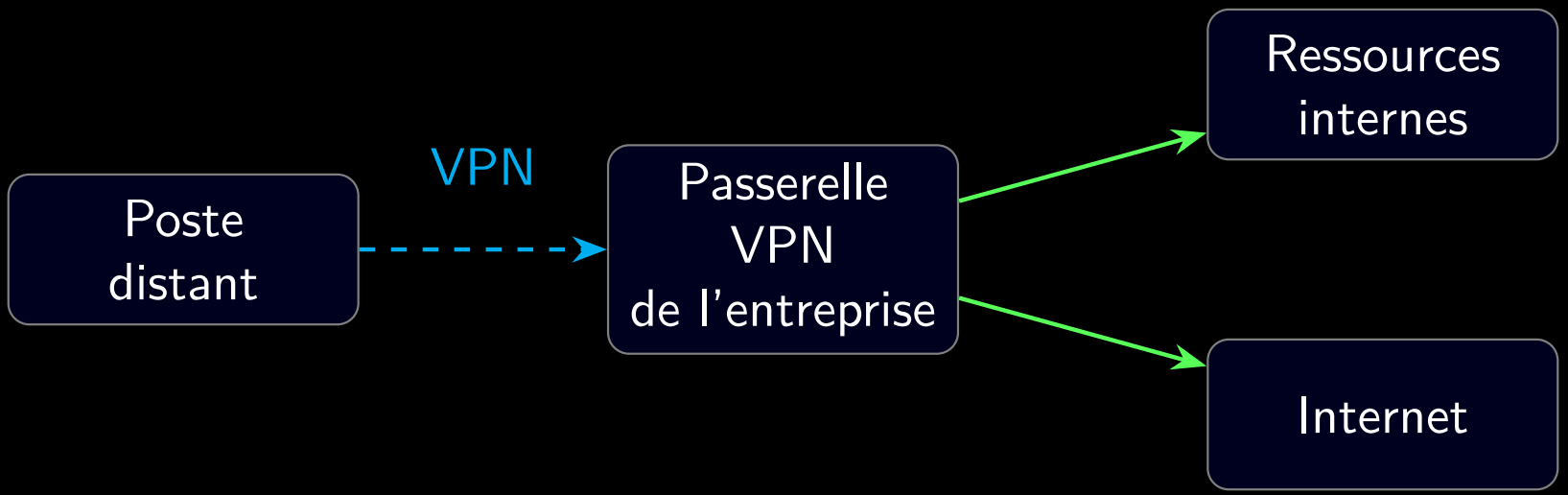
Le trafic Internet représenté ne traverse pas la passerelle VPN de l'entreprise.

- - - -➤ Tunnel chiffré ⟶ Trafic hors tunnel

Seul le sens aller est dessiné ; les échanges sont bidirectionnels.

Télétravail : full tunnel

Les flux internes et Internet passent par le VPN de l'entreprise.



L'entreprise transporte et peut filtrer les deux flux représentés.

- - - -➤ Tunnel chiffré ⟶ Trafic hors tunnel

Seul le sens aller est dessiné ; les échanges sont bidirectionnels.

Décider aussi du chemin DNS

1. Quel résolveur répond aux noms internes depuis le poste distant ?
2. Comment l'atteindre : route, tunnel et règle de filtrage ?
3. L'adresse obtenue possède-t-elle un chemin aller et retour autorisé ?
4. Que deviennent résolution et sessions à la coupure du tunnel ?

Preuve distincte

Tester la résolution, puis l'accès au service par son nom. Un ping par adresse IP ne valide pas le DNS ni l'autorisation applicative.

Protocole VPN : choisir selon les contraintes

Une même architecture peut utiliser différents protocoles.

Critère	WireGuard	IPsec / IKEv2	OpenVPN (TLS)
Compatibilité	Implémentation sur chaque extrémité	Standards IETF ; profils des équipements à vérifier	Clients / serveurs ; versions et options à vérifier
Transport	IP dans UDP	IKE : UDP 500/4500 ; ESP ou ESP sur UDP	Tunnel sur UDP ou TCP ; port configurable
Identité et clés	Clés publiques des pairs ; distribution hors protocole	Certificats, PSK ou EAP selon déploiement	Certificats TLS ; utilisateur via intégration
Exploitation	Distribuer / retirer les pairs ; routes et filtrage	Politiques, identités et associations de sécurité	Certificats, profils et intégrations d'identité

Aperçu de la section 3

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

WireGuard : quelles protections pour les échanges ?

Propriété	Mécanisme principal
Authentification	Connaissance préalable des clés publiques des pairs
Confidentialité	Chiffrement symétrique avec clés de session
Intégrité	AEAD ChaCha20-Poly1305
Forward secrecy	Contribution de clés éphémères au handshake
Anti-replay	Nonces et compteurs vérifiés à la réception
Rekeying	Renouvellement périodique des sessions

WireGuard : ce qu'il faut gérer autour du tunnel

- **Utilisateurs :** identité et authentification multifacteur (MFA).
- **Clés et révocation :** distribution fiable et retrait des pairs sur les passerelles concernées.
- **Droits d'accès :** routage, filtrage et rôles applicatifs.
- **Terminaux :** contrôle de la conformité des postes.
- **Audit :** traçabilité des accès et des actions des utilisateurs.

Ces fonctions demandent des outils et des politiques complémentaires.

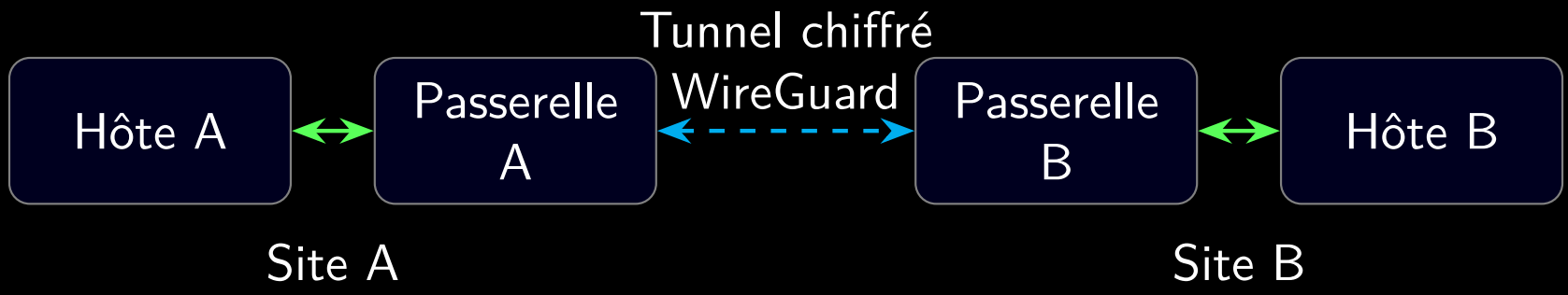
Structure d'un paquet WireGuard encapsulé



Exemple : relier deux sites avec WireGuard

Objectif

Permettre à l'hôte A de joindre l'hôte B et contrôler les échanges entre les deux sites.



- Chaque hôte utilise sa passerelle locale pour joindre l'autre site.
- Les passerelles transportent les paquets dans le tunnel et filtrent les échanges.

Exemple : adresses et tests de connectivité

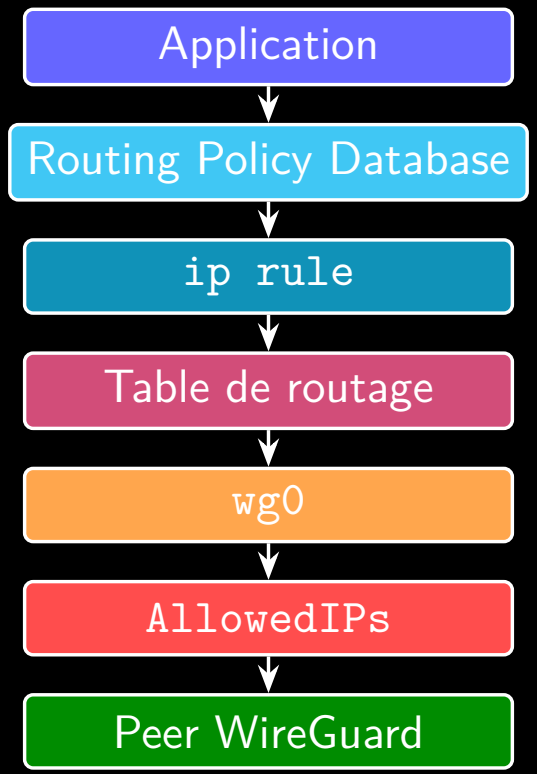
Les deux sites utilisent des réseaux LAN distincts.

Adresse	Site A	Site B
Hôte LAN	`10.100.1.10/24`	`10.100.2.10/24`
Passerelle côté LAN	`10.100.1.1/24`	`10.100.2.1/24`
Tunnel (`wg0`)	`10.200.0.1/30`	`10.200.0.2/30`
Transport du tunnel	`192.0.2.1/30`	`192.0.2.2/30`

Deux tests complémentaires

- **Entre adresses du tunnel :** de `10.200.0.1` vers `10.200.0.2`, tester la communication via WireGuard.
- **Entre hôtes LAN :** de `10.100.1.10` vers `10.100.2.10`, tester aussi les routes et le transit autorisé sur les passerelles.

WireGuard n'est pas le routage Linux



Différence entre sélectionner `wg0` par Linux et sélectionner le peer par WireGuard ?

Cryptokey routing

Sens émission

Destination IP
↓
`AllowedIPs`
↓
Sélection du peer
↓
Chiffrement

Sens réception

Peer identifié
↓
Paquet déchiffré
↓
Source IP interne
↓
Vérification `AllowedIPs`

À retenir

`AllowedIPs` associe préfixes IP et clés publiques ; ce n'est pas un firewall applicatif.

Configurer le pair : passerelle A

Lecture au format `wg-quick`, avec les adresses de la maquette :

```
[Interface]
PrivateKey = <CLE_PRIVEE_A>
Address = 10.200.0.1/30
ListenPort = 51820

[Peer]
PublicKey = <CLE_PUBLIQUE_B>
Endpoint = 192.0.2.2:51820
AllowedIPs = 10.200.0.2/32, 10.100.2.0/24
```

Lire les deux plans

`Endpoint` : joindre B sur l'underlay. `AllowedIPs` : associer l'adresse de tunnel et le LAN de B à sa clé.

Configurer le retour : passerelle B

```
[Interface]
PrivateKey = <CLE_PRIVEE_B>
Address = 10.200.0.2/30
ListenPort = 51820

[Peer]
PublicKey = <CLE_PUBLIQUE_A>
Endpoint = 192.0.2.1:51820
AllowedIPs = 10.200.0.1/32, 10.100.1.0/24
```

Vérifier la symétrie des préfixes

Pourquoi B doit-il associer `10.100.1.0/24` au pair A, alors que l'adresse de tunnel de A est `10.200.0.1` ?

Passer du lien entre pairs au site-à-site

1. Chaque hôte doit savoir rejoindre sa passerelle locale.
2. Chaque passerelle doit router le préfixe distant vers `wg0`.
3. Les `AllowedIPs` doivent associer ce préfixe au bon pair et accepter les sources légitimes à la réception.
4. Activer le forwarding et autoriser seulement les services prévus.
5. Vérifier le retour depuis le réseau distant ; justifier le NAT seulement si l'architecture en a besoin.

Le handshake et le ping entre adresses de tunnel ne prouvent pas le transit applicatif entre les sites.

Routage conditionnel : sélectionner une table

Condition choisie dans la maquette

Le trafic provenant de l'hôte A consulte la table 100 ; celui de la passerelle utilise la table principale.

```
# Selectionner une table selon la source
ip -n ns_site_a route add table 100 10.100.2.0/24 dev wg0
ip -n ns_site_a rule add priority 100 \
  from 10.100.1.10/32 lookup 100

# Observer la decision avec et sans la source LAN
ip -n ns_site_a route get 10.100.2.10 \
  from 10.100.1.10 iif lan-a
ip -n ns_site_a route get 10.100.2.10
```

Routage : que change le retrait de la règle ?

1. Avec la règle : la recherche depuis `10.100.1.10` affiche `table 100`, interface `wg0`.
2. Sans la règle de priorité 100, la même recherche change de table : la table principale est utilisée.
3. Le ping A vers B reste possible grâce à la route principale. Le refus des nouvelles requêtes B vers A reste effectif.
4. Le rétablissement de la règle sélectionne à nouveau la table 100.

Filtrer après déchiffrement

- `AllowedIPs` : association préfixes / pair cryptographique.
- `INPUT` : accès à un service de la passerelle elle-même.
- `FORWARD` : trafic traversant la passerelle vers un LAN, une DMZ ou un autre site.
- `nftables` : autoriser les flux de la matrice et leur retour, refuser les autres ; placer compteurs et journaux utiles.
- Conserver l'accès UDP aux endpoints sur l'underlay.

WireGuard derrière NAT



État observé

Le serveur apprend : `PublicKey -> endpoint IP:port` observé.

- `PersistentKeepalive` maintient le mapping NAT quand le client est silencieux.
- Si le client passe du Wi-Fi à la 5G, son identité cryptographique ne change pas.
- Le dernier paquet authentique reçu peut mettre à jour l'endpoint.

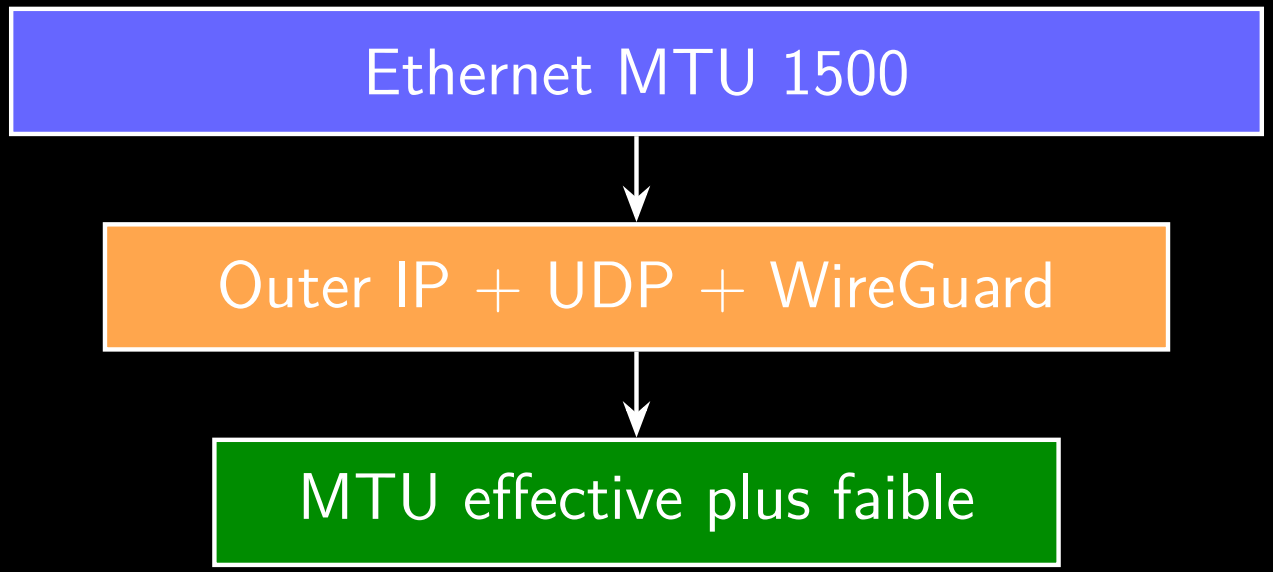
Aperçu de la section 4

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

Commandes d'exploitation

- `wg show` : handshake, endpoint, compteurs, keepalive.
- `wg-quick` : gestion simple, routes et règles automatiques.
- `ip route get` : décision de routage effective.
- `ss -lunp` : socket UDP d'écoute.
- `tcpdump -ni <iface> udp port <port-WG>` : trafic chiffré externe.

MTU et overhead WireGuard



- Encapsulation ⇒ moins de place pour le paquet IP interne.
- Risques : fragmentation, PMTUD cassé, black-hole MTU, baisse de débit.
- Symptôme classique : `ping` fonctionne, gros flux TCP bloqué ou très lent.

Diagnostiquer la MTU

Observations

```
ip -n ns_site_a link show wg0
ip netns exec ns_host_a ping -M do -s 1372 10.100.2.10
ip netns exec ns_site_a tcpdump -ni underlay-a \
  'icmp or udp port 51820'
```

Corrections possibles

- MTU explicite sur `wg0`.
- MSS clamping pour les flux TCP.
- Autoriser les ICMP nécessaires au PMTUD.

Troubleshooting WireGuard

1. Interface montée ?
2. Route correcte et table sélectionnée ?
3. Endpoint UDP joignable ?
4. Handshake récent ?
5. Compteurs RX/TX cohérents ?
6. `AllowedIPs` corrects en émission et réception ?
7. `nftables` autorise `INPUT`/`FORWARD` ?
8. Forwarding activé sur les gateways ?
9. Route retour présente ?
10. MTU/PMTUD corrects ?

Cas conducteur : le tunnel répond, mais pas le LAN

Situation

A joint B sur `10.200.0.2`. Pourtant, l'hôte A (`10.100.1.10`) ne reçoit plus de réponse de l'hôte B (`10.100.2.10`).

1. Que prouve le ping du tunnel ? Que reste-t-il à vérifier ?
2. Suivre la requête puis la réponse : route, pair, filtrage.
3. Quelle observation distingue une route retour absente d'un refus ?

Conclusion attendue

Une hypothèse, une observation qui la teste, une correction, puis un nouveau test du transit entre les hôtes.

Révocation : prouver la fin de l'accès

1. Établir un trafic autorisé et relever l'état initial.
2. Retirer l'autorisation du pair sur la passerelle de contrôle et dans sa configuration persistante.
3. Retester le flux existant et une nouvelle tentative : l'accès doit échouer au point attendu ; conserver les observations.
4. Vérifier les autres accès qui doivent rester autorisés.
5. En laboratoire, restaurer la configuration de référence et retester.

Deux opérations distinctes

Renouveler automatiquement les clés de session ne révoque pas l'autorisation d'une clé publique de pair.

Quatre tests pour défendre l'architecture

Test	Résultat attendu	Preuve à conserver
Accès autorisé	Transit LAN possible	Ping hôte à hôte ; application si déployée
Accès interdit	Refus au contrôle prévu	Compteur ou journal du refus
Route retour retirée	Panne localisée puis corrigée	Routes avant/après et nouveau test
Pair révoqué	Accès interrompu et nouvelle tentative refusée	État du pair et résultats horodatés

Pour chaque test

État initial, action, attendu, observé, interprétation et retour à l'état sain. Joindre la sélection de table et la mesure MTU ; valider le DNS si déployé, sinon documenter son chemin et son test attendu.

Que permet de conclure une observation ?

- Mesure: Un résultat observé dans un environnement identifié : le ping A vers B prouve le transit ICMP testé.
- Trace existante: Un état à interpréter dans son contexte -> un handshake récent ne prouve pas l'accès à une application.
- Scénario sur table: Un raisonnement sur les contrôles et les résultats attendus, à vérifier lors du déploiement.

Limiter la conclusion à ce qui est établi

Un résultat attendu n'est pas une mesure ; un test réseau réussi ne valide pas à lui seul l'identité ou les droits applicatifs.

Aperçu de la section 5

1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

Cas partenaire : pourquoi un accès applicatif ?

Besoin du profil étudié

Un partenaire utilise uniquement une application HTTPS en DMZ.
Il ne doit pas parcourir le LAN ni atteindre `vm-mgnt`.

- Option réseau : VPN limité et filtrage strict, avec authentification et autorisations au niveau de l'application.
- Option ZTNA (*Zero Trust Network Access*) : autorisation d'accès à l'application selon identité, appareil et contexte.
- Comparer les dépendances, les sessions, les journaux et la révocation.

Les deux options se jugent sur le besoin et les preuves ; un tunnel seul ne remplit pas toute la politique d'accès.

ZTNA : un chemin partenaire explicite

Exemple de cible, étudié sur table

Poste partenaire → point de contrôle d'accès → connecteur limité à l'application → application DMZ.

1. Le fournisseur d'identité authentifie l'utilisateur avec MFA.
2. La politique vérifie rôle, posture requise et application demandée.
3. Le point de contrôle autorise cette session ou la refuse.
4. Le connecteur atteint l'application : DNS, route, filtrage et retour doivent fonctionner ; aucun chemin direct ne doit contourner le contrôle.

Pour aller loins : NIST SP 800-207 (modèles Zero Trust).

Partenaire : trois scénarios pour éprouver les droits

Situation	Décision attendue	Élément à vérifier
Identité habilitée, poste conforme	Application autorisée ; management refusé	Politique, application et journal
Identité habilitée, posture non conforme	Accès refusé selon la politique	Signal de posture et motif du refus
Habilitation retirée en cours de session	Session arrêtée selon le délai défini ; nouvel accès refusé	Propagation, session et journal de révocation

Dépendances à discuter

Indisponibilité identité, DNS ou connecteur : quel accès devient impossible ? Quel journal permet de localiser la cause ?

Ouverture : situer SASE

Secure Access Service Edge

Une architecture de services qui réunit connectivité et sécurité pour des sites et utilisateurs distribués, généralement via le cloud.

- Peut associer SD-WAN, contrôle des accès applicatifs ZTNA, sécurité web et pare-feu fournis comme services.
- Questions ARES : où passent les flux ? Qui applique la politique ? Quelles dépendances WAN, fournisseur et identité ?
- À envisager si les besoins distribués le justifient ; aucun déploiement ni choix SASE n'est exigé pour M4.

Référence : MEF 117, cadre de services SASE.

Retour à ARES : quatre accès, quatre contrôles

Besoin	Mécanisme	Contrôle	Preuve visée
Intersite	WireGuard entre passerelles	Pairs, routes et filtrage	Transit permis ; flux interdit bloqué
Administration	Accès distant puis bastion	Identité ; passage imposé	Session tracée ; accès direct refusé
Télétravail	VPN split ou full	Droits métier ; DNS et sortie	Service par nom ; management refusé
Partenaire	ZTNA ou VPN restreint	Identité, application, session	Application seule ; révocation effective

Du réseau à l'accès complet

La maquette mesure le transit ICMP intersite. Les accès utilisateur exigent aussi des validations DNS, applicatives et d'identité.

Exercice de décision : défendre la cible ARES

1. Reprendre les besoins ARES, les zones M1, la matrice M2 et le DNS M3.
2. Dessiner intersite, administration, télétravail et partenaire ; placer les contrôles et tracer les retours.
3. Justifier les mécanismes retenus et une alternative rejetée.
4. Relier chaque autorisation et refus à son test et son niveau de preuve.
5. Examiner une panne ou un retrait de droit et expliciter les limites restantes.

Question de synthèse

Montrez un flux : pourquoi est-il autorisé, où peut-il être bloqué, et comment retirez-vous l'accès ?

Synthèse

1. Définir qui doit accéder à quel service et ce qui doit être refusé.
2. Dessiner le chemin et placer les contrôles avant de configurer.
3. Réaliser le transit LAN avec WireGuard, routage conditionnel et filtrage.
4. Prouver fonctionnement, isolation, diagnostic et révocation.
5. Étudier le ZTNA pour le partenaire ; situer SASE en ouverture.

Suite du parcours ARES

M5 approfondira l'observabilité : les preuves et points de contrôle identifiés ici deviennent des objets à superviser.

Aperçu de la section 6

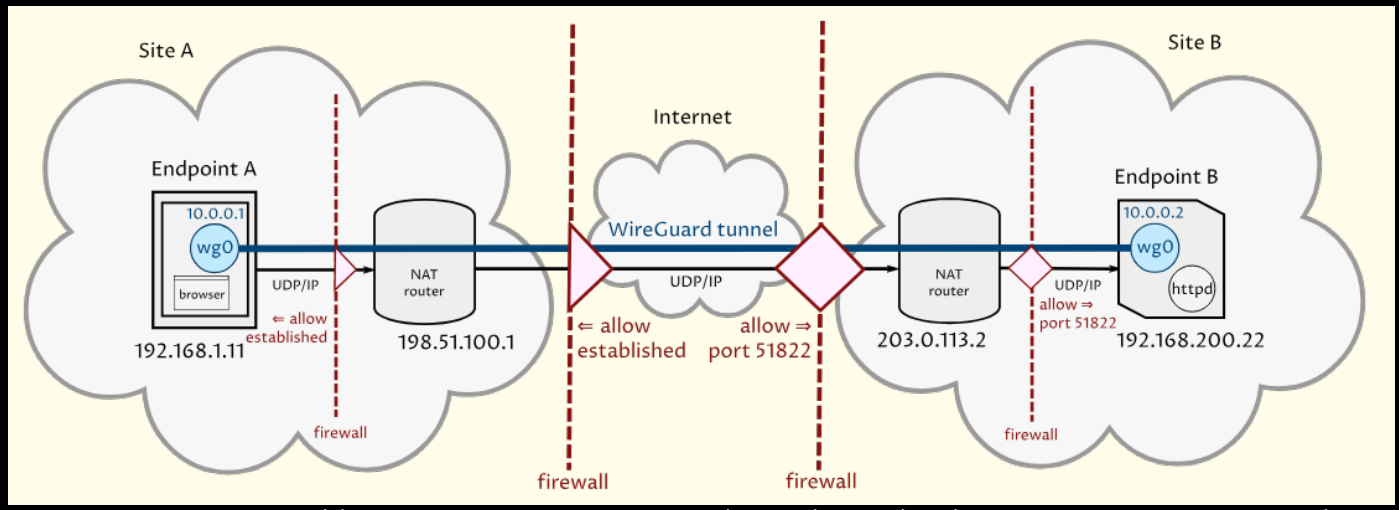
1. 1. Définir les besoins et les autorisations
2. 2. Choisir et dessiner l'architecture
3. 3. Réaliser le chemin avec WireGuard
4. 4. Valider, diagnostiquer et révoquer
5. 5. Étudier le partenaire et défendre la cible
6. Approfondissements facultatifs

À consulter selon les besoins

- Handshake et chiffrement : approfondissement cryptographique.
- Gestion avancée du full tunnel : lecture complémentaire.
- Topologies, passage à l'échelle et asymétrie : variantes du cas simple.
- Mobilité et keepalive : exploitation avancée.
- Benchmark : comparaison expérimentale optionnelle.

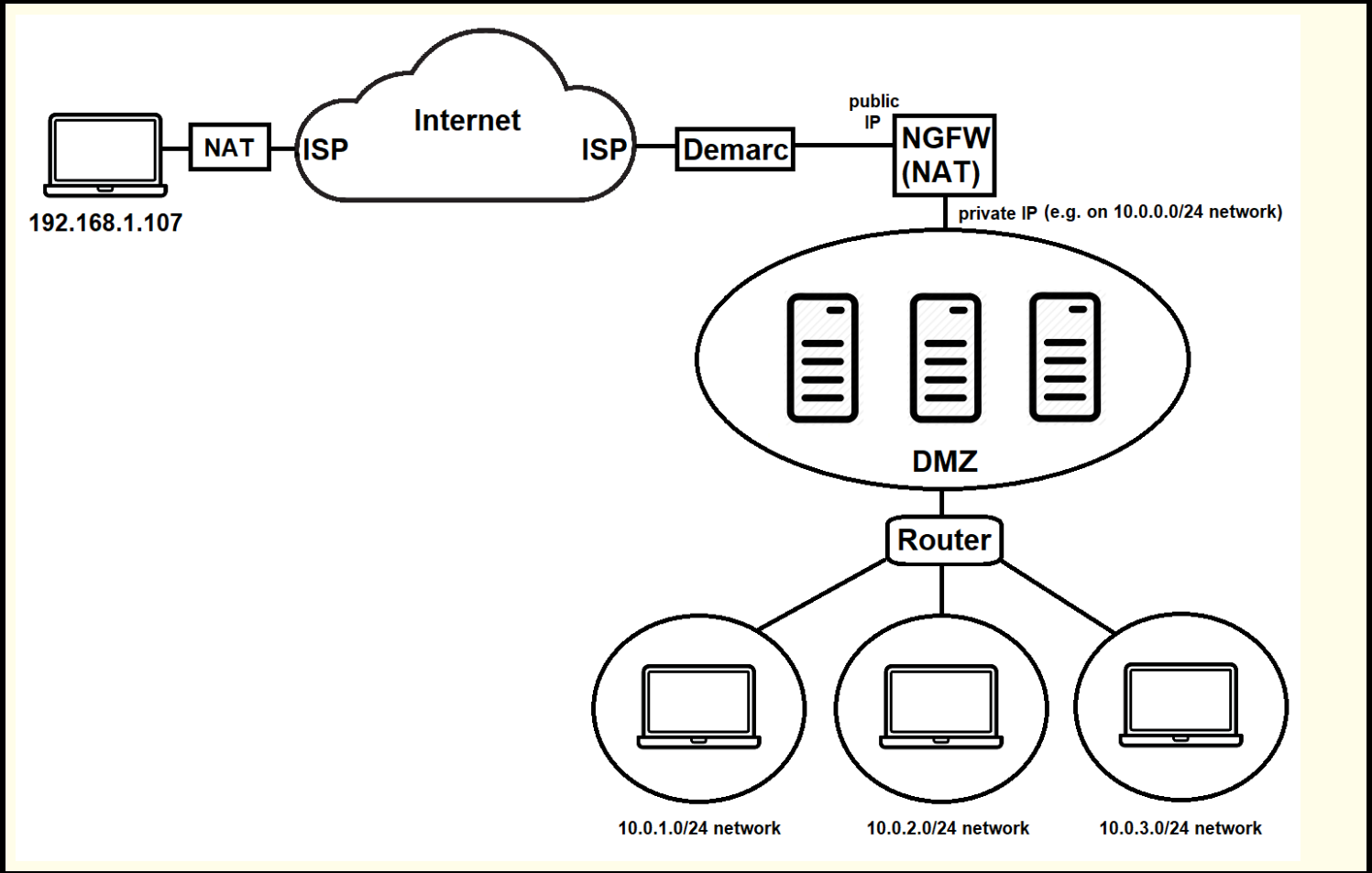
Ces compléments approfondissent le parcours principal selon les besoins.

Point to Point avec firewall



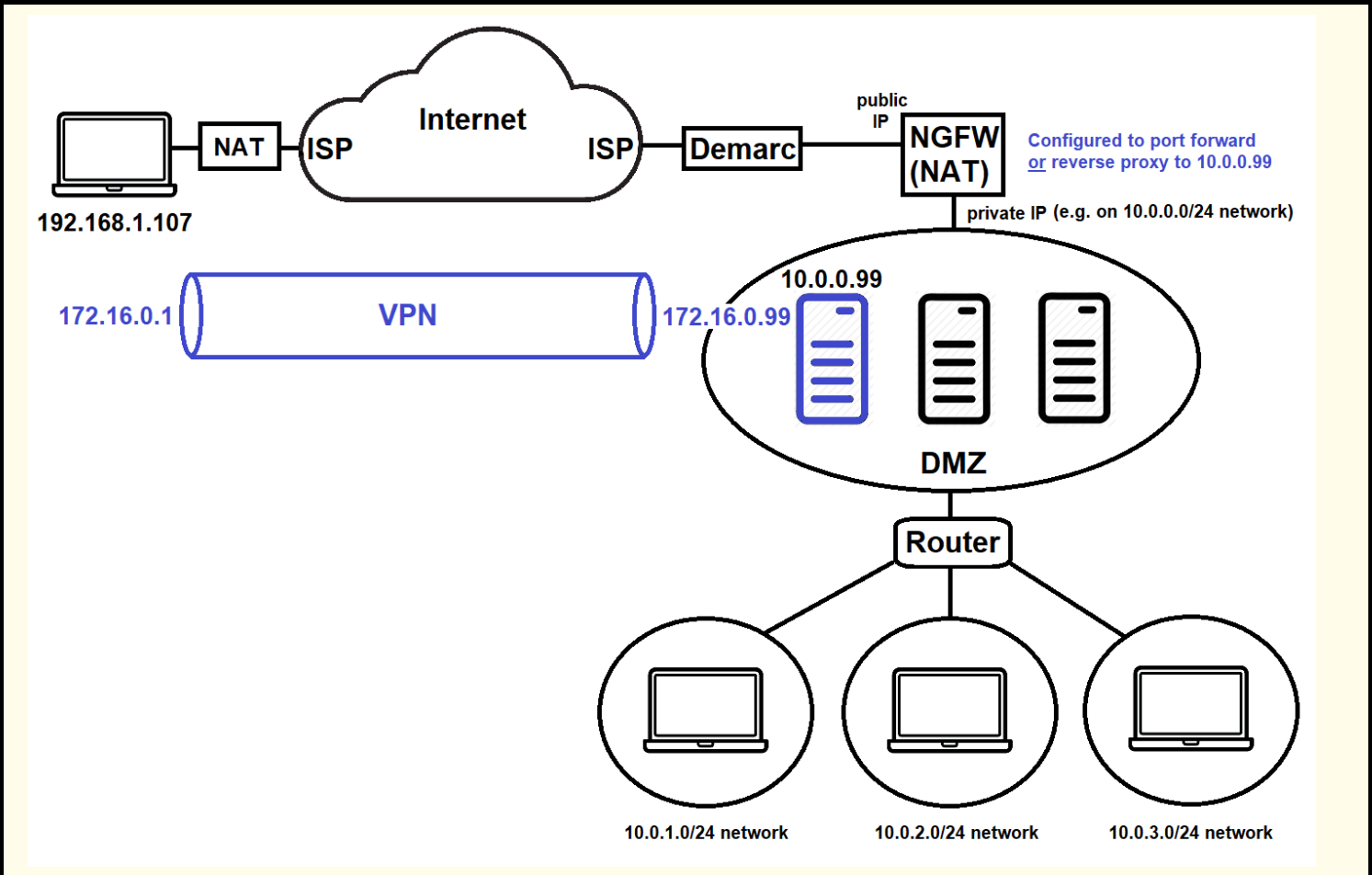
source : https://www.procustodibus.com/blog/2020/10/wireguard-topologies/

VPN + DMZ



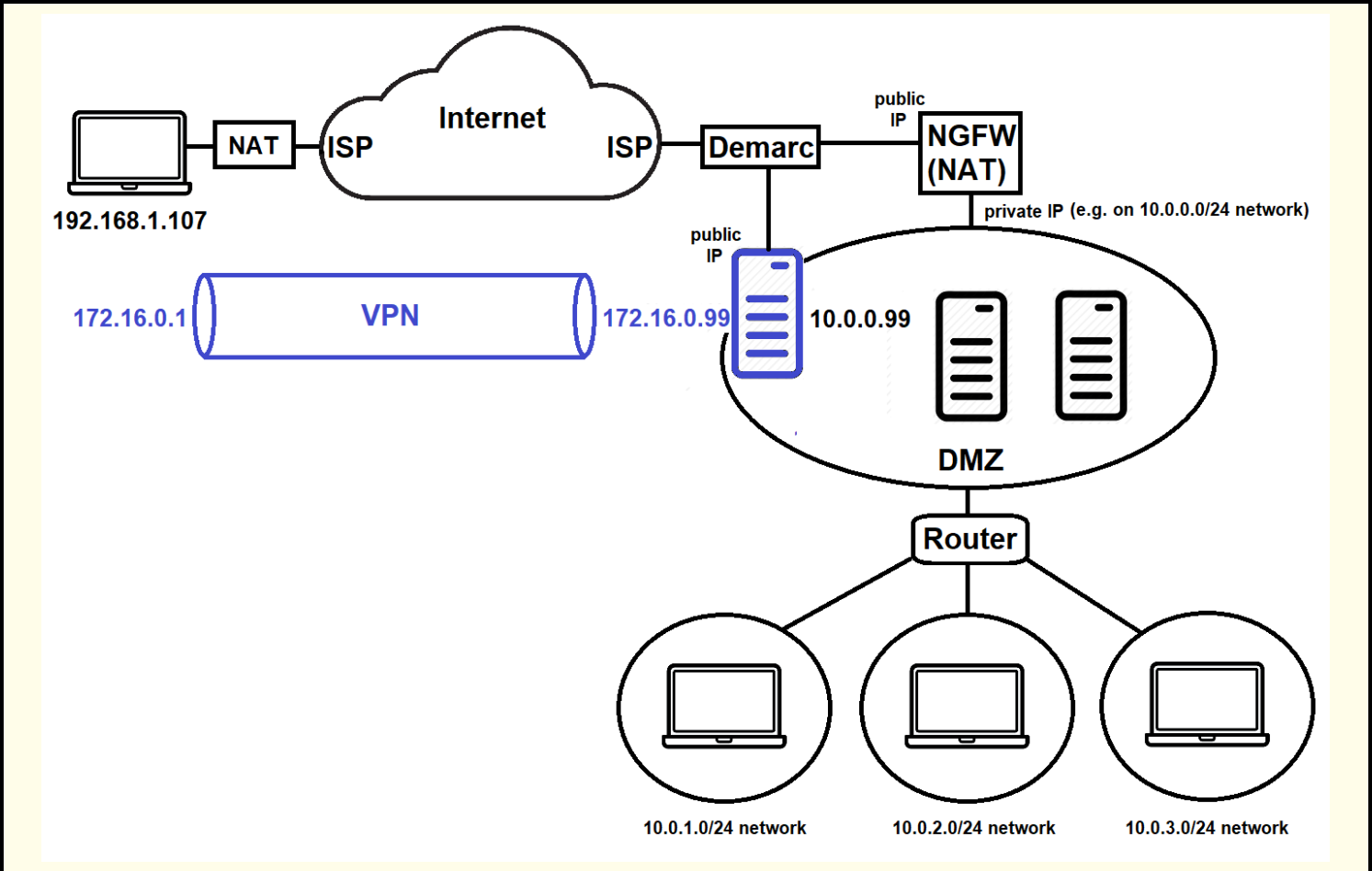
source : https://www.procustodibus.com/blog/2020/10/wireguard-topologies/

VPN + DMZ



source : https://www.procustodibus.com/blog/2020/10/wireguard-topologies/

VPN + DMZ



source : https://www.procustodibus.com/blog/2020/10/wireguard-topologies/

Architecture : mesh ou hub-and-spoke ?

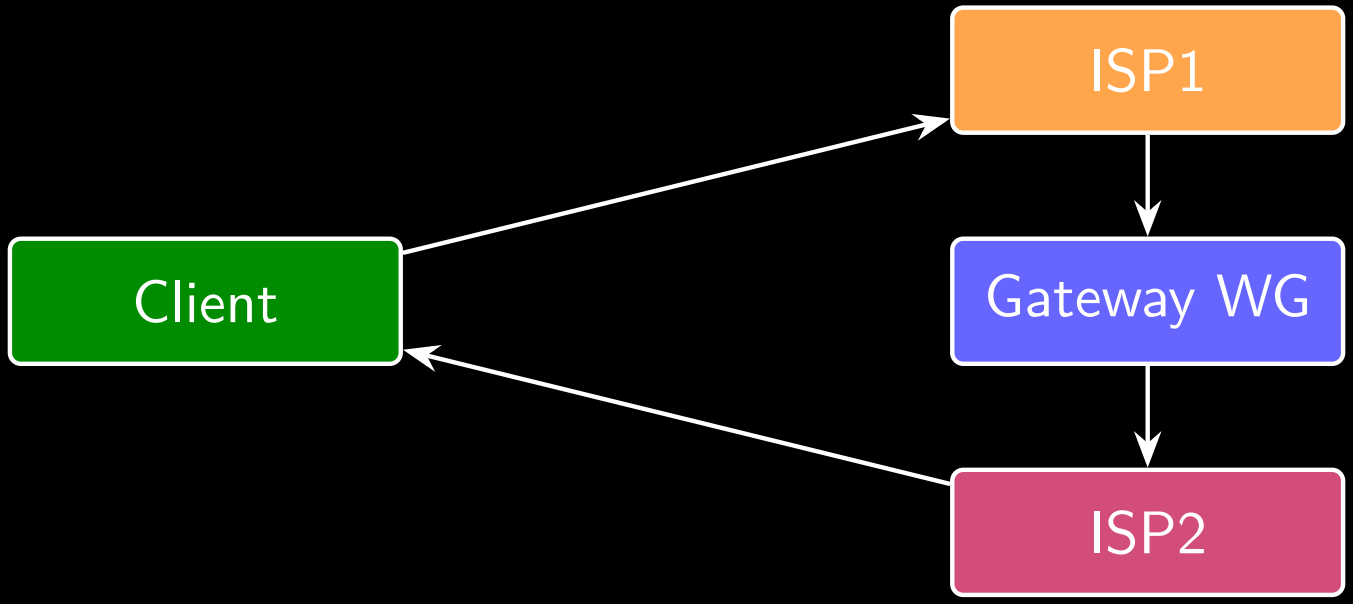
Cas

Interconnecter 10 sites, puis raisonner pour 100 sites.

- Full mesh : $\frac{N(N-1)}{2}$ tunnels.
- 10 sites : 45 tunnels.
- 100 sites : 4950 tunnels.
- Hub-and-spoke : configuration plus simple, mais dépendance au hub.

Quel impact sur la configuration, les clés, les routes, la supervision et la disponibilité ?

Asymétrie de routage



Le paquet chiffré entre par ISP1 mais la réponse sort par ISP2. Que peuvent faire `conntrack`, le NAT, `rp_filter` et le firewall stateful ?

- Conserver la symétrie par policy routing.
- Vérifier les routes retour et le filtrage `FORWARD`.

Comprendre le handshake WireGuard

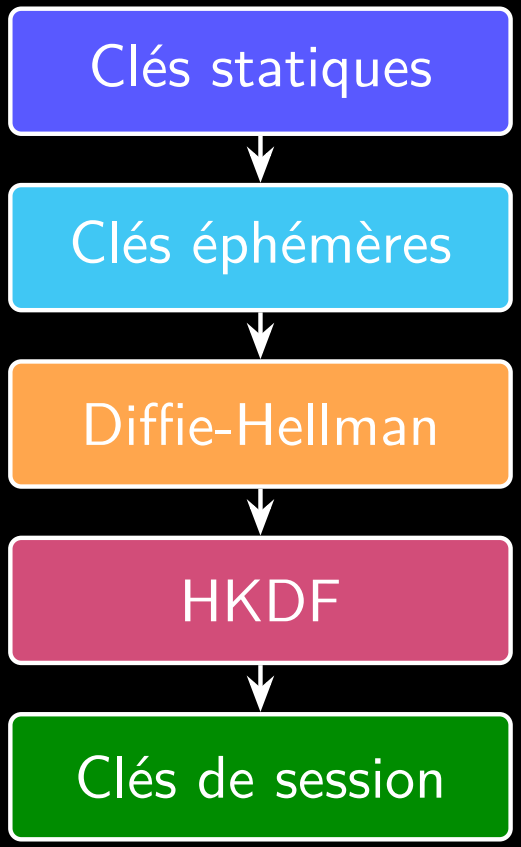
1. Les clés publiques statiques des pairs sont connues au préalable.
2. L'initiateur envoie une clé éphémère et son identité statique chiffrée.
3. Le répondeur fournit sa contribution éphémère ; les échanges Diffie–Hellman alimentent la dérivation des clés de session.
4. Après la réponse, l'initiateur émet un premier paquet chiffré qui confirme la clé au répondeur.

Primitives fixées par le protocole

Curve25519, dérivation fondée sur HMAC-BLAKE2s, chiffrement authentifié ChaCha20-Poly1305 ; secret prépartagé optionnel.

`https://www.wireguard.com/protocol/`

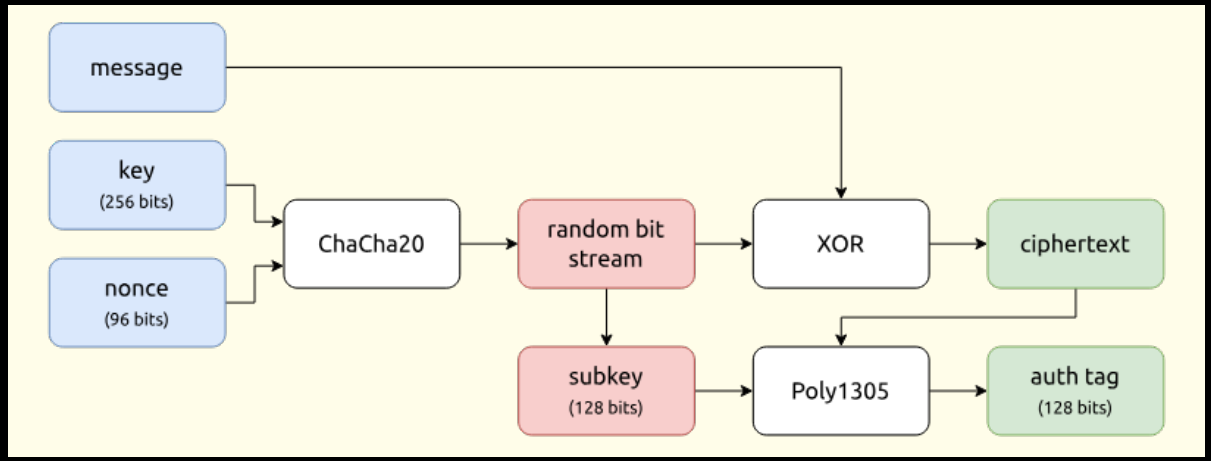
Que fournit le handshake ?



Que se passe-t-il si la clé privée d'un pair est volée aujourd'hui ?

ChaCha20-Poly1305

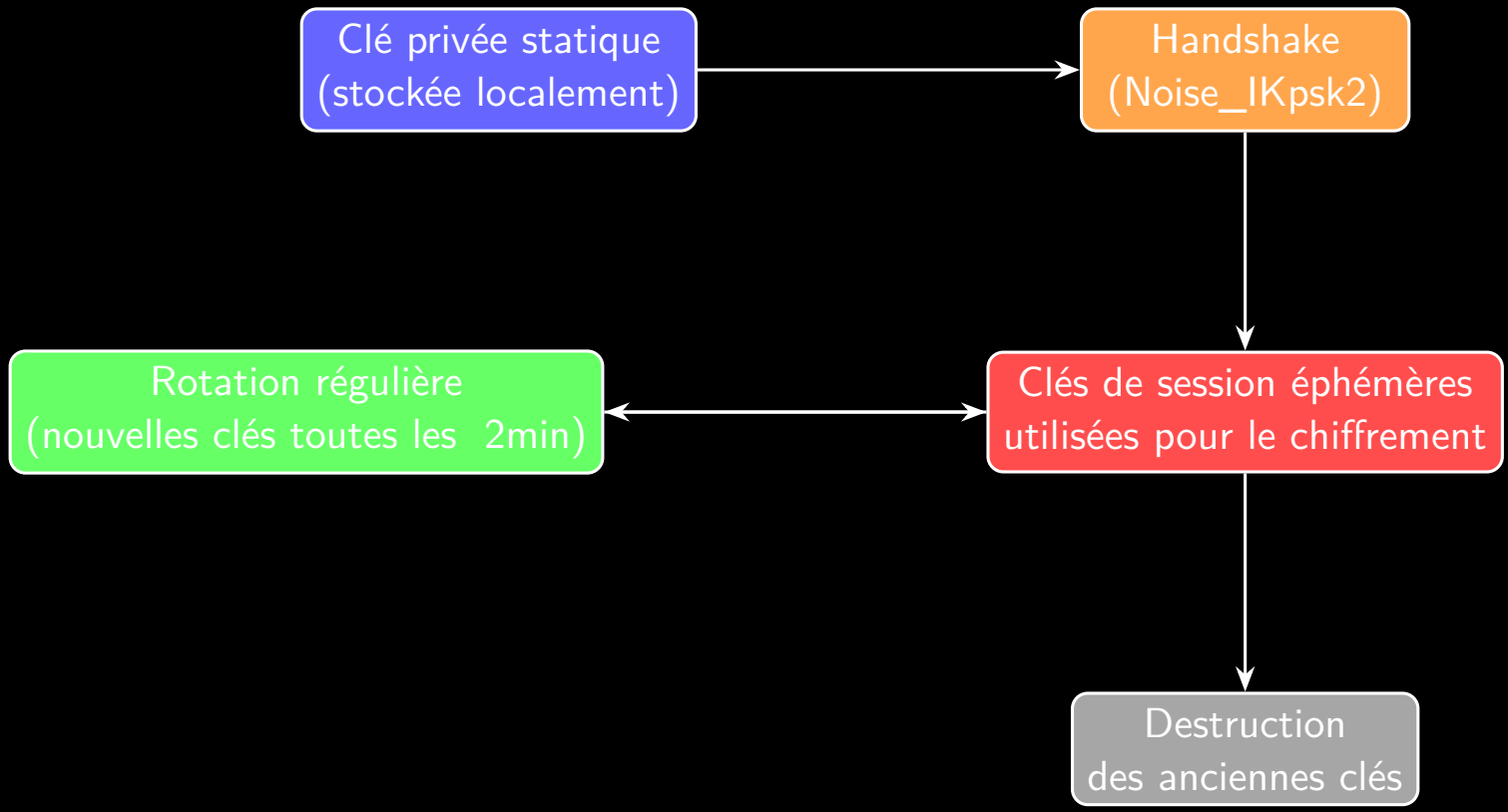
- Chiffrement rapide et sûr
- Authentification intégrée



Pour aller-loins:

- https://www.rfc-editor.org/rfc/rfc8439
- https://andrea.corbellini.name/2023/03/09/authenticated-encryption/

Gestion des clés



- **Rotation régulière** : nouvelles clés dérivées automatiquement.
- **Stockage sécurisé** : clé privée jamais transmise, clés de session effacées.

Le paradoxe du full tunnel

Problème

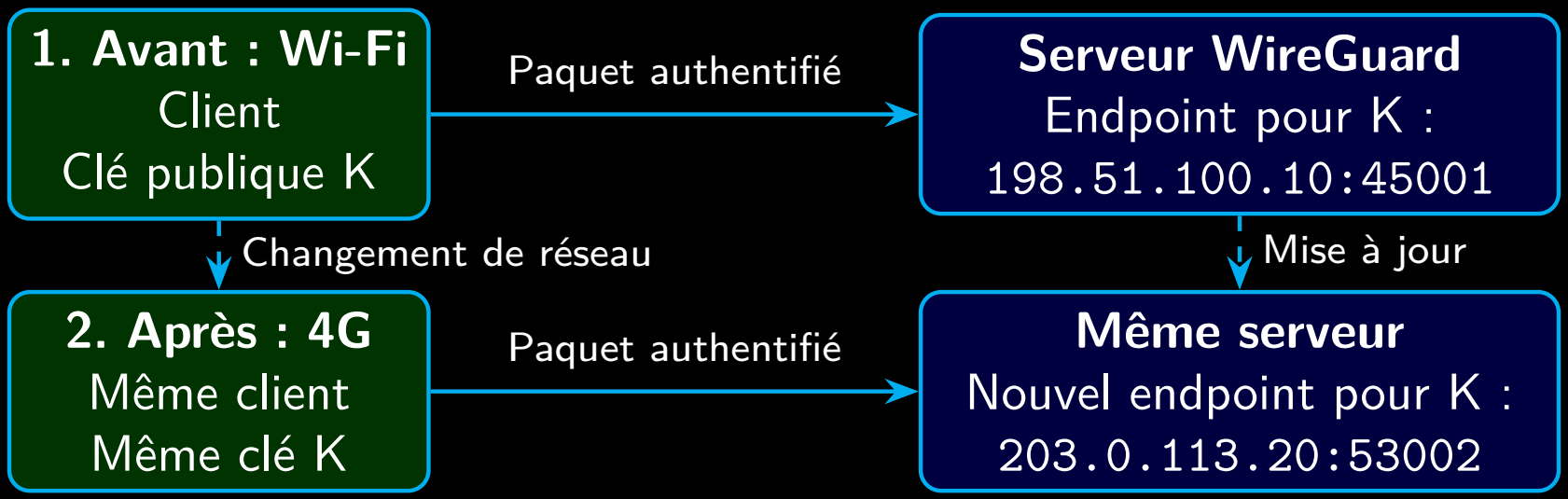
Si la route par défaut pointe vers `wg0`, comment joindre l'endpoint WireGuard public sans envoyer le paquet WireGuard dans le tunnel ?

Cas

```
default dev wg0
Endpoint = 203.0.113.10:51820
```

- Route spécifique vers l'endpoint public.
- `fwmark` pour éviter de re-router les paquets UDP WireGuard dans `wg0`.
- Tables dédiées et `ip rule`, comme le fait `wg-quick`.

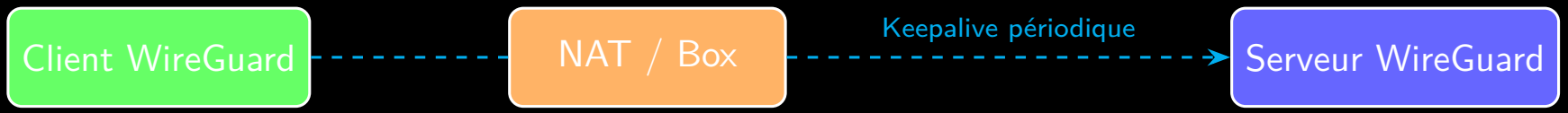
Mobilité : même client, nouvel endpoint



Les endpoints indiquent l'IP et le port **vus par le serveur**, après NAT.

La clé identifie le pair ; l'endpoint indique où lui répondre.
La mise à jour suit la réception d'un paquet authentifié du client.

Keepalive



- Envoie de petits paquets vides
- Empêche le NAT d'effacer la session
- Très léger, seulement si nécessaire

Le problème des 2000 peers

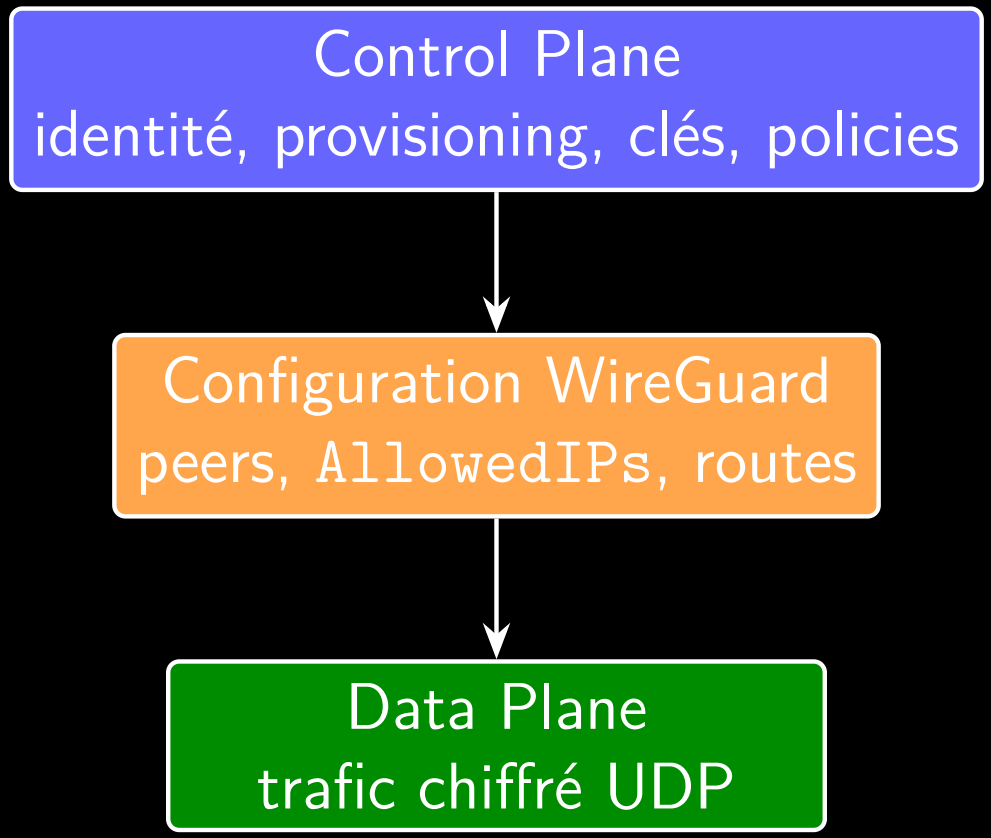
Avec deux pairs, WireGuard est simple. À grande échelle, le problème devient organisationnel.

- Générer les clés privées sans les exposer.
- Distribuer et vérifier les clés publiques.
- Révoquer un utilisateur ou une machine.
- Gérer les départs, rotations et renouvellements.
- Auditer les accès et l'activité.
- Éviter les collisions dans `AllowedIPs`.

Conclusion

WireGuard fournit un excellent data plane sécurisé, mais pas tout le control plane d'identité.

Control plane / Data plane



- WireGuard est volontairement minimaliste.
- Les solutions industrielles ajoutent souvent inventaire, RBAC, MFA, révocation, journalisation et API.

Transit hub-and-spoke



Un paquet A → B arrive sur `wg0`. Pourquoi n'est-il pas nécessairement transmis vers le peer B ?

- Forwarding Linux.
- Route vers le préfixe B.
- `AllowedIPs` du peer B.
- `nftables FORWARD`.
- NAT éventuel.

Audit et observabilité

Outil	Usage
`wg show`	État du tunnel, derniers handshakes, volume échangé
`tcpdump / tshark`	Capture et analyse du trafic UDP WireGuard
`nftables`	Compter, logguer et filtrer les paquets sur `wg0`
`journalctl / dmesg`	Logs système et éventuelles erreurs du module
`ip route get / ip rule`	Vérifier la décision de routage Linux
`conntrack -L`	Observer l'état des flux NATés ou filtrés statefully

- **Monitoring trafic** : suivre activité et volume sur `wg0`.
- **Détection anomalies** : repérer scans, absence de handshake, trafic inhabituel.

Activité optionnelle : benchmark VPN

Comparer

Sans VPN vs WireGuard vs OpenVPN

Métrique	Sans VPN	WireGuard	OpenVPN
Throughput			
RTT			
CPU			
Packet loss			

- Outils : `iperf3`, `ping`, `mpstat`, `top`.

Ressources : pratiquer et diagnostiquer

- **Maquette ARES** : `projet/01_topologie_canonique.md` ; démo : `demos/module4-wireguard/README.md`.
- **Configurer WireGuard** : Quick Start officiel — interfaces, clés, pairs et keepalive derrière NAT.
- **Routage et full tunnel** : Routing & Network Namespaces — routes, marques et namespaces Linux.
- **Filtrage et MSS clamping** : Manuel officiel nftables — chaînes, conntrack et modification de l'option TCP MSS.
- **MTU du chemin** : RFC 1191 (IPv4) et RFC 8201 (IPv6) — PMTUD ; RFC 6691 — taille MSS et options TCP.
- **Observer les paquets** : Guide officiel Wireshark — captures, filtres et décodage des protocoles.

Références : protocoles et architectures

- **WireGuard** : Protocol & Cryptography et article technique de J. A. Donenfeld — handshake, cryptokey routing et clés de session.
- **Chiffrement authentifié** : RFC 8439 — ChaCha20 et Poly1305 — confidentialité et intégrité des données.
- **Encapsulation GRE** : RFC 2784 — Generic Routing Encapsulation — format du tunnel et considérations de sécurité.
- **Architecture IPsec** : RFC 4301 — Security Architecture for IP — politiques et associations de sécurité.
- **Zero Trust** : NIST SP 800-207 (2020) — principes, décision et application du contrôle d'accès.
- **SASE** : MEF 117 — cadre et attributs des services SASE — articulation des services réseau et de sécurité.